

Documento de Especificación de Requerimientos y Diseño (MVP)

Proyecto: Suite Aprovechamiento del Tiempo

Estatus: Arquitectura Conceptual y API de Enlace Validadas

Enfoque: Seguridad en Capas (Defense in Depth) y Privacidad por Diseño (Privacy by Design)

1. Resumen Ejecutivo del Sistema

La **Suite Aprovechamiento del Tiempo** es una plataforma diseñada para automatizar y optimizar el registro de asistencia del personal, adaptándose de forma resiliente a entornos con retos de infraestructura y conectividad local. El sistema se divide en dos grandes componentes funcionales:

1. **Panel de Administración Web:** Un asistente guiado (Wizard) para la configuración inicial de sedes, gestión de roles de supervisión y carga masiva de empleados.
2. **Agente Autónomo de Interacción (SOFY):** Un bot integrado con la API de WhatsApp encargado del registro georreferenciado diario de los empleados y la canalización interactiva de solicitudes de permisos.

2. Especificaciones Funcionales por Etapas (El Wizard)

Paso 1: Alta de Sedes y Geocercas

- **Interfaz Visual:** Panel de control dividido en dos columnas. La izquierda contiene el formulario de datos (Nombre de la Sede, Dirección) y controles deslizantes (Sliders) para el radio de tolerancia espacial. La derecha integra un mapa detallado basado en la librería de código abierto **Leaflet.js**.
- **Lógica de Geocercas:** El mapa interactivo visualiza el radio de tolerancia como un círculo translúcido azul. Al hacer clic en el mapa, las coordenadas (latitud y longitud) se capturan automáticamente en el formulario.
- **Restricciones de Backend:** El radio de tolerancia se restringe estrictamente a un rango de entre 30 y 150 metros (con un estándar óptimo sugerido de 50 metros). Las coordenadas se procesan en formato WKT (Well-Known Text) como un objeto geométrico POINT(longitud latitud) nativo para almacenamiento relacional geoespacial en **PostGIS**.

Paso 2: Gestión de Accesos, Roles y Seguridad

- **Formulario Unificado:** Captura obligatoria de Nombre Completo, Correo Electrónico y Teléfono Celular. Permite la asignación jerárquica de roles entre *Administrador Global* (acceso total a la suite) y *Supervisor de Sede* (vinculado estrictamente a una delimitación física del Paso 1).
- **Cláusula de Privacidad Legal:** La interfaz bloquea el botón de registro hasta que el

Administrador confirme explícitamente el consentimiento de uso de datos personales mediante una casilla de verificación (Checkbox). Si el backend recibe una petición con valor falso en esta validación, interrumpe el flujo emitiendo un código de error de cumplimiento 400 Bad Request.

- **Mecanismos de Recuperación y Autonomía:** Implementación de flujos de auto-gestión de credenciales ("¿Olvidó su contraseña?"). El sistema dispara notificaciones redundantes en paralelo por correo y teléfono celular (WhatsApp) con enlaces únicos basados en tokens efímeros que expiran en 15 minutos.

Paso 3: Carga Masiva y Consentimiento de Empleados

- **Métodos de Entrada:** Registro individual para ingresos nuevos, y carga por lotes (Batch Processing) mediante archivos de plantilla estructurados en formato CSV o Excel.
- **Doble Validation de Consentimiento (Double Opt-In):** Al guardar la nómina, el sistema encola solicitudes automáticas hacia la pasarela de WhatsApp. **SOFY** inicia un flujo interactivo presentándose y solicitando autorización expresa al trabajador antes de permitirle enviar registros de ubicación.

3. Arquitectura de Ciberseguridad y Protección de Datos

El backend, desarrollado sobre el framework de alta velocidad **FastAPI**, implementa directrices estrictas de cifrado simétrico para mitigar riesgos ante accesos no autorizados a la infraestructura persistente:

Elemento de Datos	Tipo de Tratamiento en Backend	Mecanismo de Protección	Comportamiento en Operación
Número Telefónico Celular	Cifrado Inmediato Simétrico	Algoritmo estándar AES-256	Se almacena de forma enmascarada en base de datos. Solo se descifra en memoria efímera al disparar alertas o recibir marcas.
Correo Electrónico	Ofuscación e Inyección Cifrada	Enmascaramiento visual (ej. c***@email.com)	Protección total de la identidad del trabajador en notificaciones de previsualización y logs del sistema.
Contraseñas de Acceso	No Almacenamiento en Texto Plano	Flujo de Token de Un Solo Uso	El sistema no crea ni transmite claves. Los usuarios las autogestionan a

Elemento de Datos	Tipo de Tratamiento en Backend	Mecanismo de Protección	Comportamiento en Operación
			través de canales seguros y temporales.

4. Lógica de Interacción Operativa (El Canal con SOFY)

A diferencia de los administradores y supervisores de la interfaz web, los empleados operativos no manejan credenciales de inicio de sesión tradicionales. Su validación de identidad se asienta completamente sobre su identificador de línea telefónica previamente verificado y encriptado en el sistema.

- **Registro de Asistencias diarias:** El empleado interactúa de forma directa con el chat de WhatsApp de SOFY enviando su "Ubicación en Tiempo Real". PostGIS calcula instantáneamente la distancia euclidiana respecto al punto central de la sede asignada; si el empleado se encuentra dentro del margen parametrizado (ej. 50 metros), la entrada se registra exitosamente.
- **Gestión del Ciclo de Vida del Dispositivo:** Si un trabajador experimenta la pérdida del equipo o cambia de línea telefónica, el administrador actualiza el registro desde el panel web seguro, lo que revoca automáticamente los accesos del número anterior y dispara un nuevo flujo de Double Opt-In al nuevo terminal de destino.